

SIMATS ENGINEERING (SAVEETHA SCHOOL OF ENGINEERING)
Department of Computer Science and Engineering
ASSESSMENT TOOL 3 – INCIDENT RESPONSE (MONITORING & MITIGATION)

Course Code:	CSA5803	Course Title:	DEVSECOPS ENGINEERING AND APPLICATION SECURITY
CO Assessed:	CO5 – Precision (BL1, BL2, BL3)	Assessment:	Assessment Tool 3
Weightage:	30% of CIA	Total Marks:	100
CO5 Statement:	Develop Incident Response Plan, Analyze Security Monitoring Dashboard, Recommend Mitigation Strategies and Technical Justification.		
Student Name:	M.GOKUL	Reg. No.:	192565067
Section / Batch:	2025 /B-TECH (CSE)	Date:	27/08/2026

Instructions to Students

- Develop an incident response plan based on the given security incident scenario and identified findings.
- Analyze the provided security monitoring dashboard, alerts, logs and indicators to determine incident status and affected assets.
- Recommend prioritized mitigation strategies that directly address the identified threats, vulnerabilities and incident impact.
- Provide clear technical justification for each major response and mitigation decision using evidence from the scenario.
- Present the response plan, dashboard analysis and recommendations clearly and professionally within the prescribed submission format.

Question Type	Focus Area	Questions	Marks
INCIDENT RESPONSE	Monitoring & Mitigation	Q1	Q1 – 100
GRAND TOTAL:		100 Marks	

Cloud Storage Security Incident: Incident Response Plan and Mitigation Strategies

1. Executive Summary

The given security incident involves suspicious activity in a cloud-storage environment. Security monitoring alerts indicate that a single user account performed a large number of file downloads and later attempted to delete files. This sequence is highly suspicious because mass downloading may indicate unauthorized data collection, while deletion attempts may indicate sabotage or an attempt to destroy evidence.

The incident must be treated as a high-priority security event. The affected account may have been compromised through stolen credentials, phishing, password reuse, malware or stolen access tokens. Another possibility is malicious insider activity. The organization should not immediately assume the identity of the attacker but should perform a detailed investigation.

The incident response plan should include identification, containment, investigation, eradication, recovery and lessons learned. The organization should immediately restrict the affected account, revoke active sessions, preserve logs and investigate all file activity. Long-term security improvements should include Multi-Factor Authentication, object versioning, Data Loss Prevention, anomaly detection, least privilege and continuous monitoring.

2. Introduction

Cloud storage is an important part of modern information systems. Organizations use cloud platforms to store, access, share and manage large amounts of data. Employees can access files from different devices and locations, making cloud storage useful for business operations.

However, cloud storage also creates security challenges. If a user account is compromised, an attacker may gain access to sensitive files. The attacker may download confidential information, modify important files, change access permissions or delete business-critical data.

In this scenario, security alerts indicate that one account performed mass file downloads followed by deletion attempts. This pattern is unusual and may indicate a serious security incident. The organization must quickly investigate the account, identify affected resources and prevent further damage.

The main objectives of the response are to protect data confidentiality, maintain data integrity and ensure data availability.

3. Incident Scenario and Problem Statement

The cloud-storage monitoring system detected unusual activity from a single account. The account downloaded a large number of files within a short period and later attempted to delete cloud-storage objects.

This creates two major security concerns. First, mass downloads may indicate that confidential information is being collected or removed from the organization. Second, deletion attempts may result in the loss of important data or may represent an attempt to hide malicious activity.

The major questions in this incident are:

- Was the account compromised?
- Was the activity performed by the legitimate user?
- How many files were downloaded?
- Were sensitive files involved?
- Were any files successfully deleted?
- Was data transferred outside the organization?

- Were permissions changed?
- Was the same device normally used by the account owner?

The security team must investigate these questions before determining the final root cause.

4. Incident Classification and Impact Assessment

The incident should initially be classified as a **high-severity cloud security incident** because it may affect confidentiality, integrity and availability.

The confidentiality of data may be affected because files were downloaded. If the files contain sensitive information, unauthorized data exposure may have occurred.

The integrity of data may be affected if the attacker modified files, permissions or cloud configurations.

The availability of data may be affected if important files were successfully deleted.

The affected assets may include:

- Cloud user account
- Cloud storage
- Sensitive files
- IAM credentials
- API keys
- Access tokens
- Security logs
- Cloud applications

A high-priority incident response is necessary because additional activity could result in greater damage.

5. Security Monitoring and Alert Analysis

Security monitoring is important because it provides visibility into suspicious cloud activity. The monitoring dashboard should be analyzed carefully to understand the complete sequence of events.

Important information includes:

- Number of downloaded files
- Time of file downloads
- Number of deletion attempts
- Success or failure of deletions
- User identity
- Source IP address
- Device information
- Geographic location
- API activity
- Permission changes

The security team should compare the current activity with the normal behavior of the account.

For example, if the user normally downloads 20 files per day but suddenly downloads 5,000 files within one hour, this behavior should be considered suspicious.

The sequence of mass downloading followed by deletion is particularly important because both events together create a stronger indication of malicious activity.

6. Investigation and Evidence Collection

The organization must collect evidence to determine what happened during the incident.

Important evidence includes:

- Cloud audit logs
- Authentication logs
- IAM logs
- Storage access logs
- Download records
- Deletion records
- IP addresses
- Device information
- API logs
- DLP alerts

The evidence should be preserved carefully. Security logs should not be deleted or modified during the investigation.

The investigation should create a timeline of events. The timeline should show when the suspicious login occurred, when mass downloading started, when deletion attempts occurred and when containment actions were performed.

Proper evidence collection helps the organization determine the root cause of the incident.

7. Root Cause Analysis

Root cause analysis is used to determine why the incident occurred.

Possible causes include:

Compromised Credentials

An attacker may have obtained the user's password through phishing, malware or password reuse.

Stolen Access Token

An attacker may have obtained a cloud access token or active session.

Malicious Insider

An authorized employee may intentionally misuse access.

Excessive Permissions

The user may have been given more access than required.

Compromised API Key

An exposed API key may have been used by an attacker.

Automated Attack

A malicious script may have downloaded and attempted to delete files.

The organization must investigate the technical evidence before confirming the root cause.

8. Complete Incident Response Plan

A complete incident response plan should include the following stages:

1. Preparation
2. Identification
3. Containment
4. Investigation
5. Eradication
6. Recovery
7. Lessons Learned

Each phase is important for controlling the incident and reducing future risks.
The organization should maintain documented procedures for cloud security incidents.

9. Immediate Containment Strategy

Containment should begin as soon as the incident is confirmed.

The affected account should be temporarily restricted or suspended. This prevents additional downloads and deletion attempts.

The organization should also:

- Revoke active sessions
- Revoke access tokens
- Disable compromised API keys
- Restrict dangerous permissions
- Preserve logs
- Monitor related accounts

The goal is to stop the attack without destroying important evidence.

The organization should also review whether the attacker created new accounts, permissions or external sharing links.

10. Eradication and Recovery

Eradication means removing the cause of the incident.

The organization should:

- Reset the affected password
- Reconfigure MFA
- Revoke compromised tokens
- Remove unauthorized API keys
- Remove malicious permissions
- Investigate the affected device
- Remove malicious software

After eradication, recovery can begin.

The organization should restore deleted files using:

- Object versioning
- Cloud backups
- Disaster recovery systems

After restoration, the organization should verify that files are complete, accurate and accessible only to authorized users.

11. Mitigation Strategies

The organization should implement multiple security controls to prevent similar incidents.

Important mitigation strategies include:

- Enforcing MFA
- Implementing object versioning
- Using DLP
- Deploying anomaly detection
- Applying least privilege
- Monitoring cloud activity

- Centralizing logs
- Implementing SIEM
- Reviewing IAM permissions
- Training employees

No single security control can completely prevent every incident. Therefore, a layered security approach should be used.

12. Technical Justification for Multi-Factor Authentication

Multi-Factor Authentication provides additional protection for user accounts.

A normal password may be:

- Stolen
- Leaked
- Guessed
- Reused
- Captured through phishing

MFA requires another verification factor.

For example:

Password + Authentication Application

If an attacker obtains only the password, the attacker may still be unable to access the account.

MFA is important in this incident because the suspicious activity came from a single account. If the account was compromised using stolen credentials, MFA could have reduced the possibility of unauthorized access.

13. Technical Justification for Object Versioning

Object versioning stores multiple versions of files in cloud storage.

When a file is modified or deleted, an earlier version may still be available.

This is important because the incident includes deletion attempts.

Object versioning provides:

- Recovery from accidental deletion
- Recovery from malicious deletion
- Protection against unauthorized modifications
- Improved business continuity

The organization can restore an earlier version of an important file instead of permanently losing the data. Object versioning should also be supported by secure backups and recovery testing.

14. Technical Justification for Data Loss Prevention

Data Loss Prevention protects sensitive information from unauthorized access and movement.

DLP can identify sensitive information such as:

- Personal information
- Financial records
- Customer data
- Source code
- Business documents

In this incident, DLP can help determine whether the downloaded files contained sensitive information. DLP can:

- Monitor large downloads
- Detect sensitive data
- Generate alerts
- Restrict unauthorized transfers
- Prevent risky sharing

DLP is useful because it focuses on the value and sensitivity of data rather than only the number of files.

15. Technical Justification for Anomaly Detection

Anomaly detection identifies behavior that is different from normal activity.

The system can monitor:

- Login time
- Download volume
- Device information
- Geographic location
- File deletion activity

For example, a user may normally download 50 files per week. If the same user suddenly downloads 5,000 files within one hour, anomaly detection can generate an alert.

In this incident, the combination of mass downloading and deletion attempts creates a strong behavioral anomaly.

Therefore, anomaly detection can improve early detection of account compromise and insider threats.

16. IAM and Least-Privilege Improvements

Identity and Access Management controls access to cloud resources.

The principle of least privilege means that users should receive only the permissions necessary for their work.

For example, a user who only needs to read documents should not automatically have permission to delete thousands of files.

Organizations should:

- Review permissions regularly
- Remove unused accounts
- Limit administrator access
- Use role-based access control
- Monitor privilege changes

Least privilege reduces the amount of damage that can occur when an account is compromised.

17. Logging, SIEM and Monitoring Rules

Centralized logging is important for detecting and investigating cloud incidents.

A SIEM can collect logs from:

- Cloud storage
- IAM
- Authentication systems
- Firewalls
- Endpoints
- DLP tools

The SIEM can correlate events.

For example:

Unusual Login → Mass Download → Deletion Attempt

The SIEM can recognize this sequence as a high-risk event.

Recommended monitoring rules include:

- Alert on unusual download volume
 - Alert on unusual deletion activity
 - Alert on new devices
 - Alert on unusual login locations
 - Alert on privilege changes
 - Alert on large sensitive-data transfers
-

18. Risk Assessment

Risk assessment helps the organization understand possible consequences.

Important risks include:

Data Exposure

Confidential information may be exposed.

Data Loss

Important files may be deleted.

Account Compromise

Attackers may continue using stolen credentials.

Business Disruption

Deleted data may interrupt business operations.

Compliance Risk

Sensitive information exposure may create legal or regulatory problems.

The organization should prioritize risks based on likelihood and impact.

19. Roles and Responsibilities

A security incident requires coordination between multiple teams.

Incident Response Lead

Coordinates the entire incident response.

Security Analyst

Analyzes alerts and logs.

Cloud Administrator

Manages cloud resources and recovery.

IAM Administrator

Restricts accounts and manages permissions.

Forensic Team

Investigates technical evidence.

Data Owner

Determines the importance of affected information.

Management

Makes important business decisions.

Clear responsibilities reduce confusion during an incident.

20. Communication and Escalation Plan

Communication is important during a security incident.

The incident response team should be notified immediately.

Relevant stakeholders may include:

- Security team
- Cloud administrators
- Management
- Data owners
- Legal and compliance teams

Sensitive information should only be shared with authorized individuals.

Regular updates should be provided during the investigation.

The organization should avoid sharing confidential technical details through uncontrolled communication channels.

21. Implementation Roadmap

The security improvements should be implemented according to priority.

Immediate Actions

- Restrict affected account
- Revoke active sessions
- Preserve evidence
- Stop further deletion

Short-Term Actions

- Investigate the incident
- Reset credentials
- Restore affected files
- Review permissions

Long-Term Actions

- Enforce MFA
- Enable object versioning
- Deploy DLP
- Implement anomaly detection
- Improve monitoring

A roadmap helps the organization implement security improvements in an organized way.

22. Lessons Learned

After the incident is resolved, the organization should perform a post-incident review.

The review should identify:

- What happened
- When it happened
- How it was detected
- How quickly it was contained
- What data was affected
- Whether recovery was successful
- Which controls failed
- Which improvements are required

The lessons learned should be used to improve future security operations.

23. Importance of Cloud Storage Security

Cloud storage security is important because modern organizations depend on cloud platforms for daily operations.

Cloud systems may contain large volumes of:

- Customer information
- Business documents
- Financial information
- Source code
- Personal information

If cloud accounts are compromised, the attacker may access this information from anywhere.

Cloud security should therefore include strong authentication, access control, encryption, monitoring and data recovery.

24. Cloud Data Exfiltration

Data exfiltration means the unauthorized removal of information.

Mass file downloads may indicate possible data exfiltration.

An attacker may download confidential information and later transfer it outside the organization.

The organization must investigate:

- Number of downloaded files
- File sensitivity
- External sharing
- Network activity
- Transfer destinations

DLP and cloud monitoring can help identify potential data exfiltration.

25. User and Entity Behavior Analytics

User and Entity Behavior Analytics monitors user activity and creates a normal behavior pattern.

The system can learn:

- Normal login time
- Normal location
- Normal device
- Normal download volume

If a user suddenly performs unusual activity, the system can identify it.

For example:

Normal Activity: 20 files per day

Suspicious Activity: 5,000 files in one hour

UEBA is useful for detecting compromised accounts and insider threats.

26. Automated Incident Response

Automated incident response can reduce the time required to stop an attack.

For example:

Suspicious Activity Detected

↓

Security Alert Generated

↓

Risk Level Increased

↓

Account Automatically Restricted

↓

Security Team Notified

Automation can reduce response time.

However, automated controls should be carefully configured because incorrect actions may interrupt legitimate users.

27. Data Classification

Data classification helps organizations understand the sensitivity of information.

Data can be classified as:

Public

Information that can be shared publicly.

Internal

Information intended for employees.

Confidential

Sensitive business information.

Highly Confidential

Critical information requiring strong protection.

Data classification helps the organization prioritize incidents.

For example, downloading 100 public files may have less impact than downloading 100 highly confidential files.

28. Backup and Disaster Recovery

Backup and disaster recovery are important for restoring data after deletion or system failure.

A backup strategy should protect against:

- Accidental deletion
- Malicious deletion
- System failure
- Cyberattacks
- Cloud configuration errors

The recovery process should include:

1. Identifying affected data.
2. Selecting the correct backup.
3. Restoring the data.
4. Verifying data integrity.
5. Checking access permissions.

Backups should be tested regularly. An organization should not assume that a backup will work without testing it.

Object versioning and backups should work together to improve data recovery